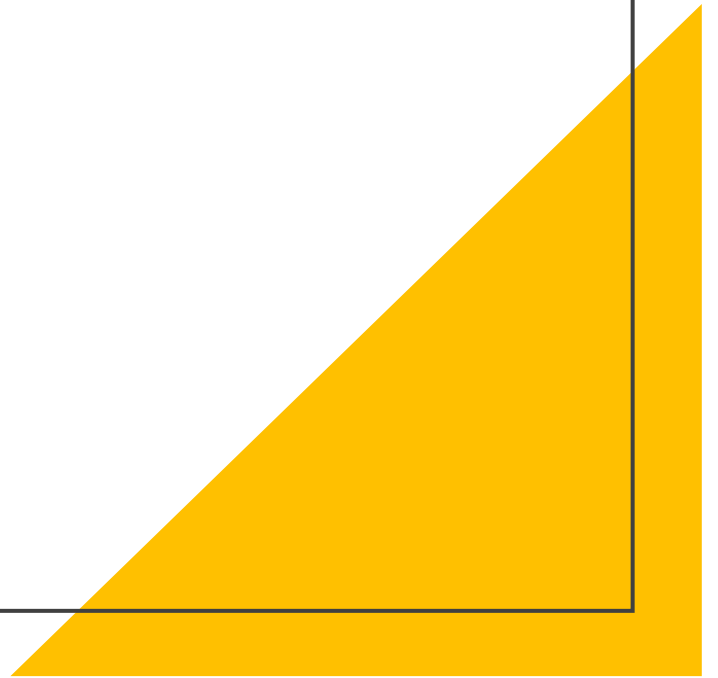


# Sociotechnical Security

CS 8803/4803

Professor Veronica Rivera

Lecture 3 – User mental models



# Last time

- History of sociotechnical security in the context of major internet events
- Survey of human-centered and empirical tools for doing sociotechnical security research
  - Qualitative studies
  - Survey studies
  - Usability studies
  - Measurement studies
- Brainstormed research questions for a prompt on scams

# Today

- Lecture user mental models
  - High-level overview of PGP
  - Examples of techniques to elicit mental models from users
- Discussion on readings

# But first: Continue activity

You are a researcher tasked with improving how we detect scams online and helping users identify/recover from scams. Your team believes that scammers might be using generative AI tools to conduct their operations.

Task: What part of this problem could you solve with the tools we've covered, what research questions would you ask, and what would you need to do to collect data?

- Qualitative (Interviews)
- Surveys
- Usability
- Measurement (Web crawling/scraping)
- Put your responses here: <https://bit.ly/45RHBwH>

# User mental models

# Why Johnny Can't Encrypt

USENIX

Home • About USENIX • Events • Membership • Publications • Students

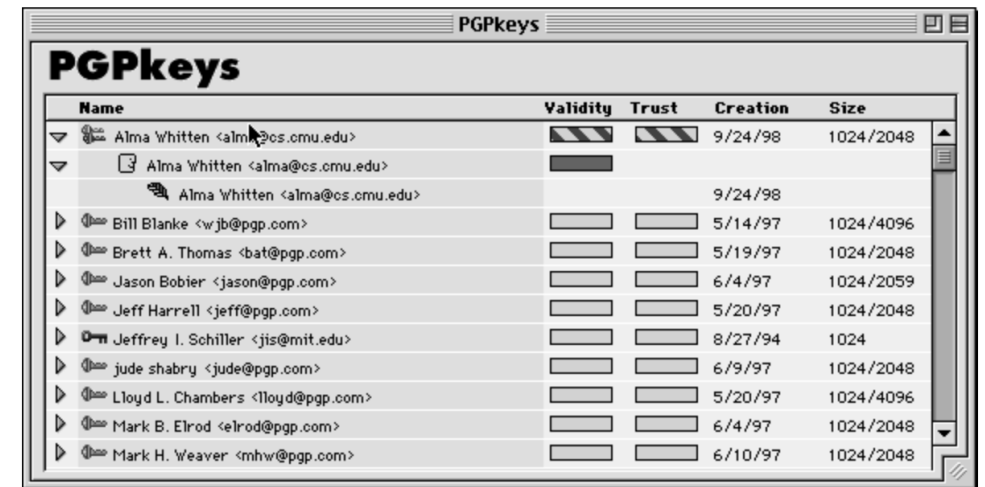
**Paper - Proceedings of the 8th USENIX Security Symposium, August 23-36, 1999, Washington, D.C.** [Technical Program]

Pp. 169–184 of the *Proceedings*

## Why Johnny Can't Encrypt: A Usability Evaluation of PGP 5.0

Alma Whitten  
School of Computer Science  
Carnegie Mellon University  
Pittsburgh, PA 15213  
[alma@cs.cmu.edu](mailto:alma@cs.cmu.edu)

J. D. Tygar<sup>1</sup>  
EECS and SIMS  
University of California  
Berkeley, CA 94720  
[tygar@cs.berkeley.edu](mailto:tygar@cs.berkeley.edu)



# PGP

- Goal:
  - Keep emails secret
  - Prevent them from being modified
  - Verify their authorship
- Techniques: encryption and signing for emails
- We'll discuss:
  - Encryption
  - Digital signatures
  - Contact & key management

# Public-Key Encryption

- Step 1: Generate (random) keys

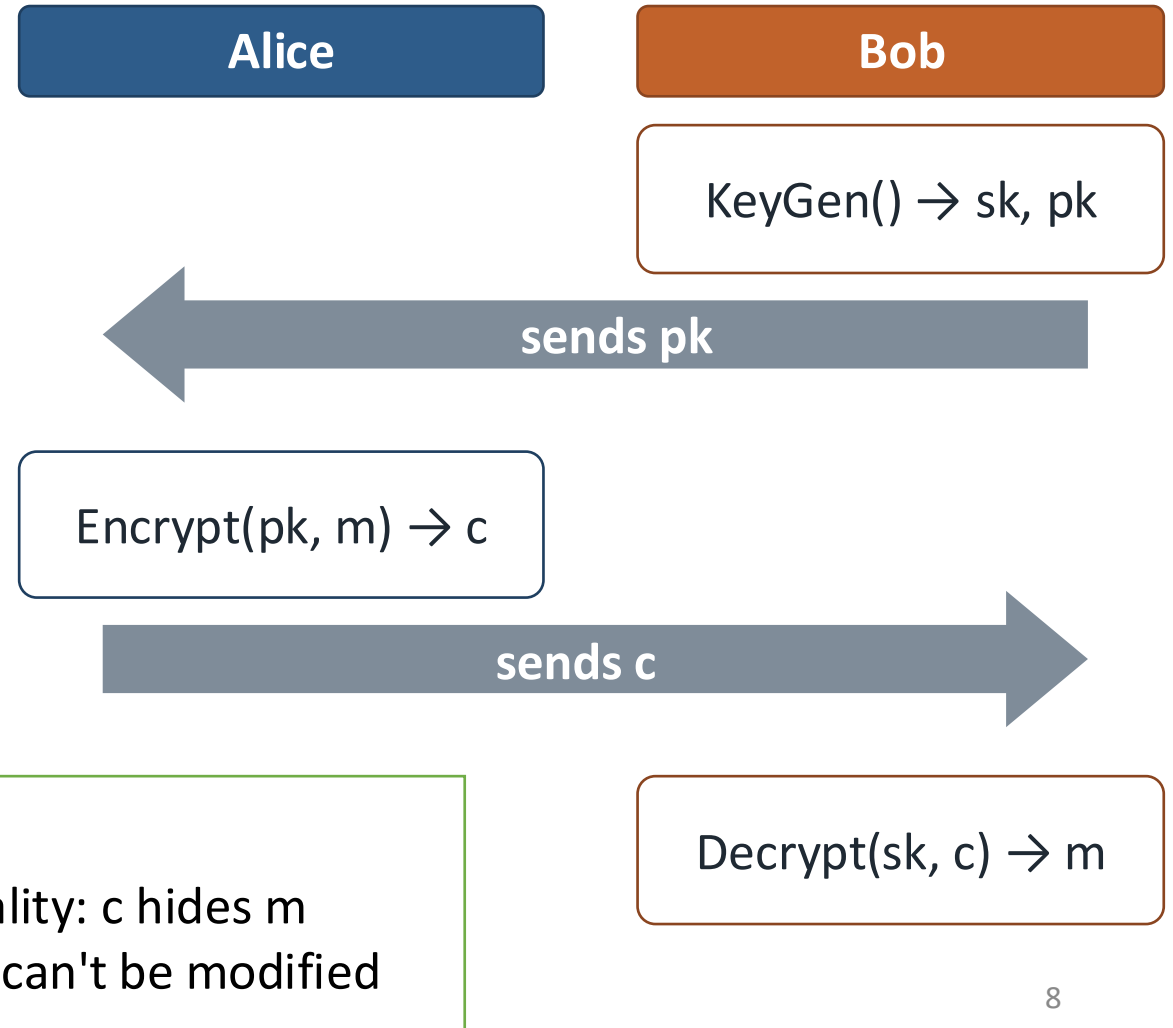
- $\text{KeyGen}() \rightarrow \text{sk}, \text{pk}$ 
  - Secret key **sk**---for receiving
  - Public key **pk**---for sending

- Step 2: Encrypt a message

- $\text{Encrypt}(\text{pk}, m) \rightarrow c$ 
  - Message **m**
  - Ciphertext **c**

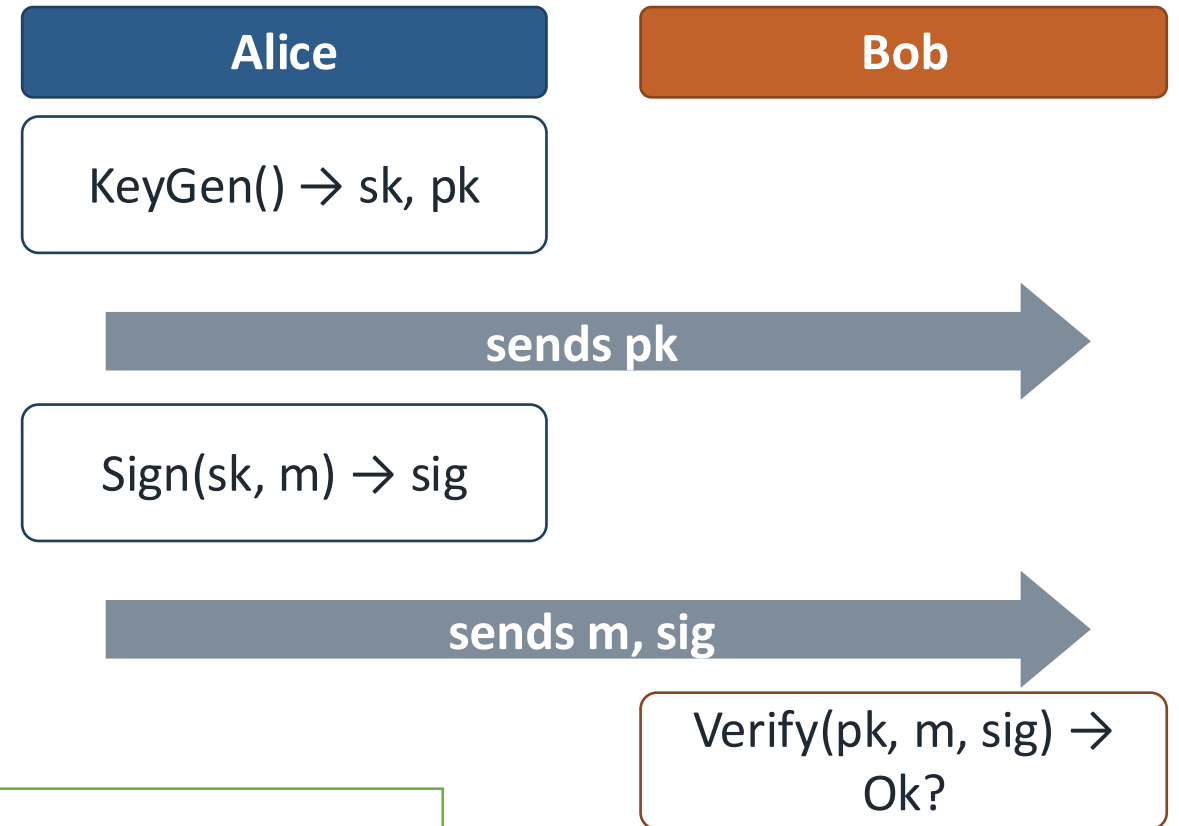
- Step 3: Decrypt a message

- $\text{Decrypt}(\text{sk}, c) \rightarrow m$



# Signatures

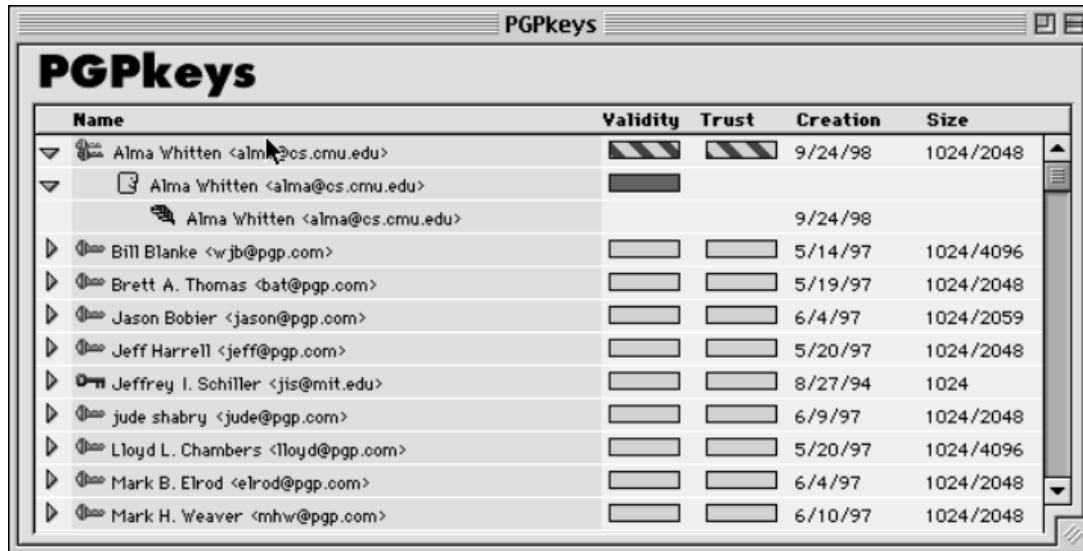
- Step 1: Generate keys
  - $\text{KeyGen}() \rightarrow \text{sk}, \text{pk}$
- Step 2: Sign message
  - $\text{Sign}(\text{sk}, m) \rightarrow \text{sig}$ 
    - **sig**: the signature
- Step 3: Verify signature
  - $\text{Verify}(\text{pk}, m, \text{sig}) \rightarrow \text{Ok?}$



Security:

- Integrity: can't forge **sig** on new **m**

# Contact/Key Management



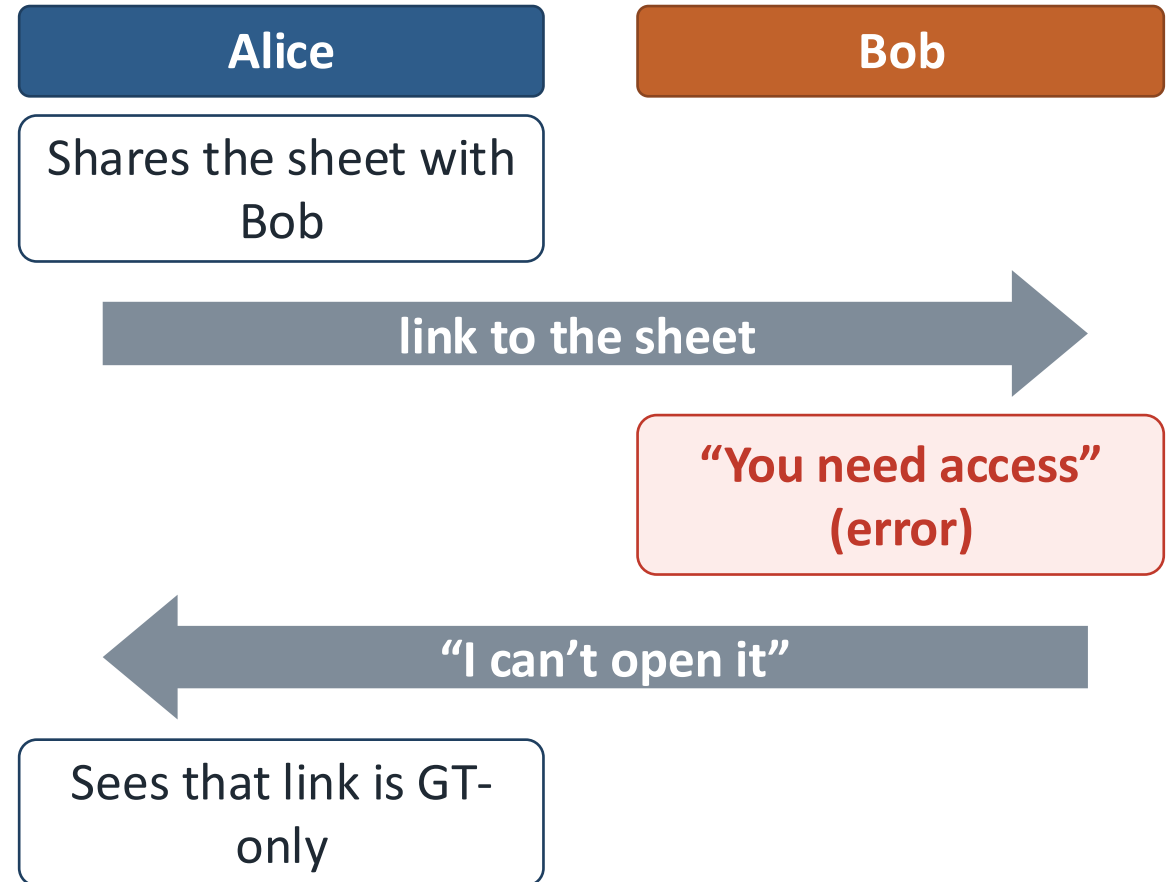
- Key problem: what is Alice's pk?
- Solution: address book/key database
  - Stores **names**, **emails**, and **pks**
- "Validating" Alice's **pk** means:
  - It is her **pk**, so you can encrypt to her
- "Trusting" Alice's pk means:
  - You "validate" every pk that she does
  - Transitive validation
- Also, there are revocations/expirations

# What is a mental model

- Example: we just saw a mental model for PGP
- Definition: a model someone has in their mind about how a system works
- Used in practice to make decisions
  - Step 1: User has a goal
  - Step 2: User thinks about what actions achieve that goal *in their model*
    - *This is the decision-making step!*
  - Step 3: User uses the interface to take those actions

# Why mental models are important in security?

- UIs often give poor feedback on incorrect mental models
  - Sharing example:
    - Alice's model: link gives access
    - Real model: link + GT gives access
- This is especially true for mental models that cause insecurity
  - Insecurity rarely causes an **error**.



# How are these models studied?

- Interviews, surveys, online studies
- Ask participants to describe how something works
- Ask participants to describe their experience, how they made a decision
- Ask participants what is happening, how they would respond to a hypothetical scenario
- Ask participants to draw a picture of how something works
- Ask participants to sort (card sorting), compare, select
- Compare responses of experts and non-experts

# Example 1: Mental models of encryption

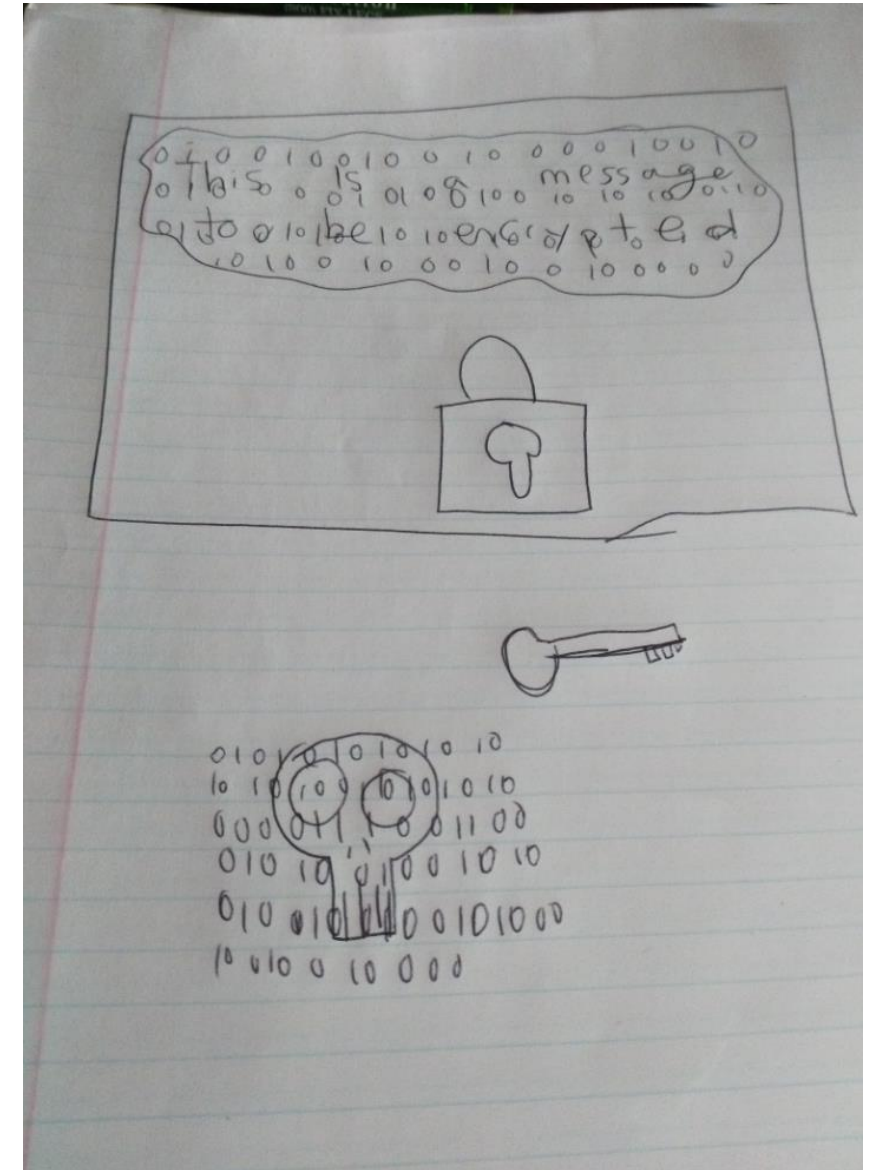
[When is a Tree Really a Truck? Exploring Mental Models of Encryption](#)

[Justin Wu and Daniel Zappala](#) (SOUPS 2018)

- First paper to study users' mental models of encryption
  - *If all you knew was that a tool “used encryption,” what would you understand about it, and how would your mental model guide your efforts to interact with it?*
- Semi-structured phone interviews with 19 participants
  - Standard questions
  - Diagramming activity to visually demonstrate their perception of encryption
- Focused on three dimensions: what encryption is, how it works, and its role in their lives.

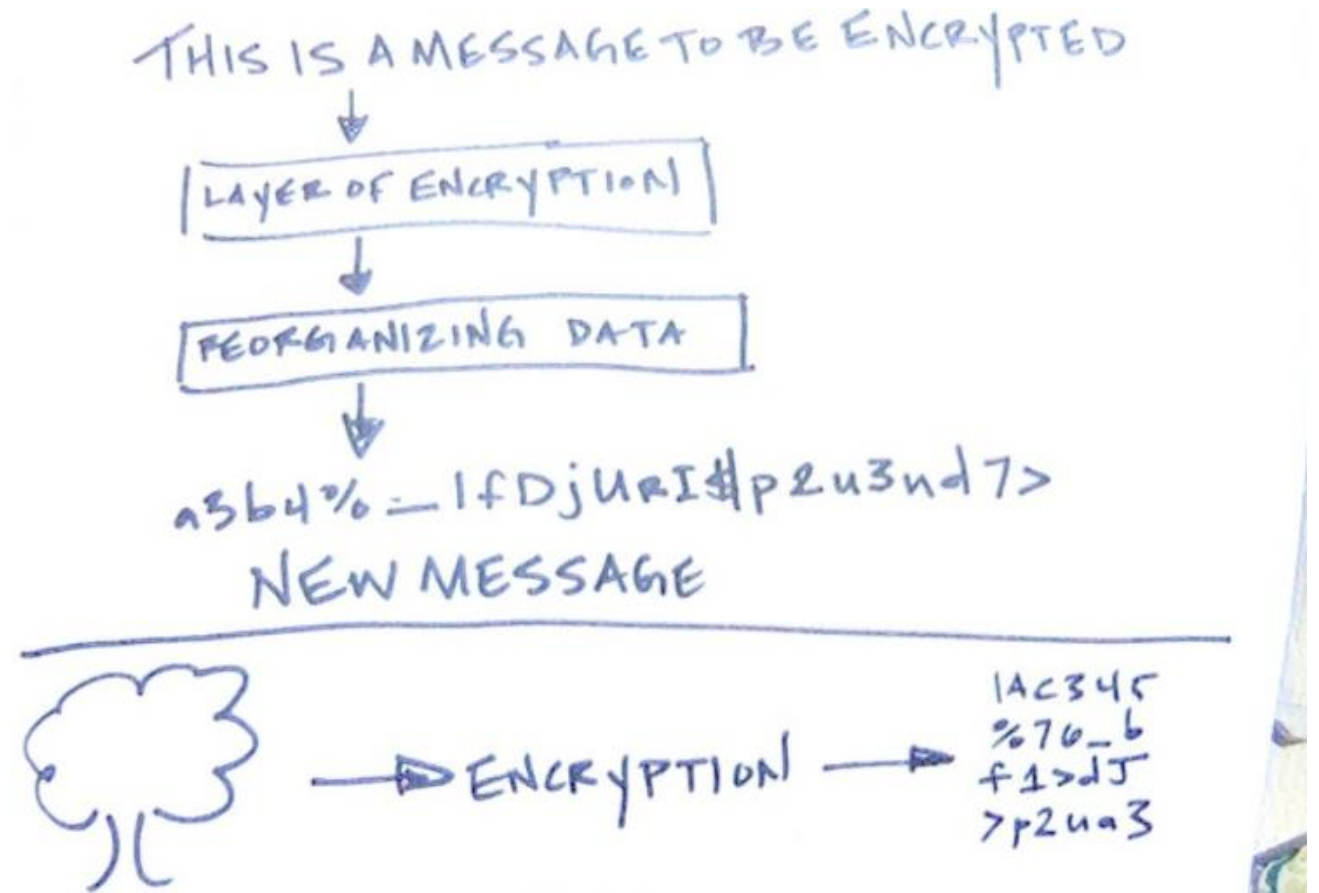
# Model 1: Access control

- Encryption does not transform data; it just blocks access
- Encryption is like putting up a wall
- Encryption = locking



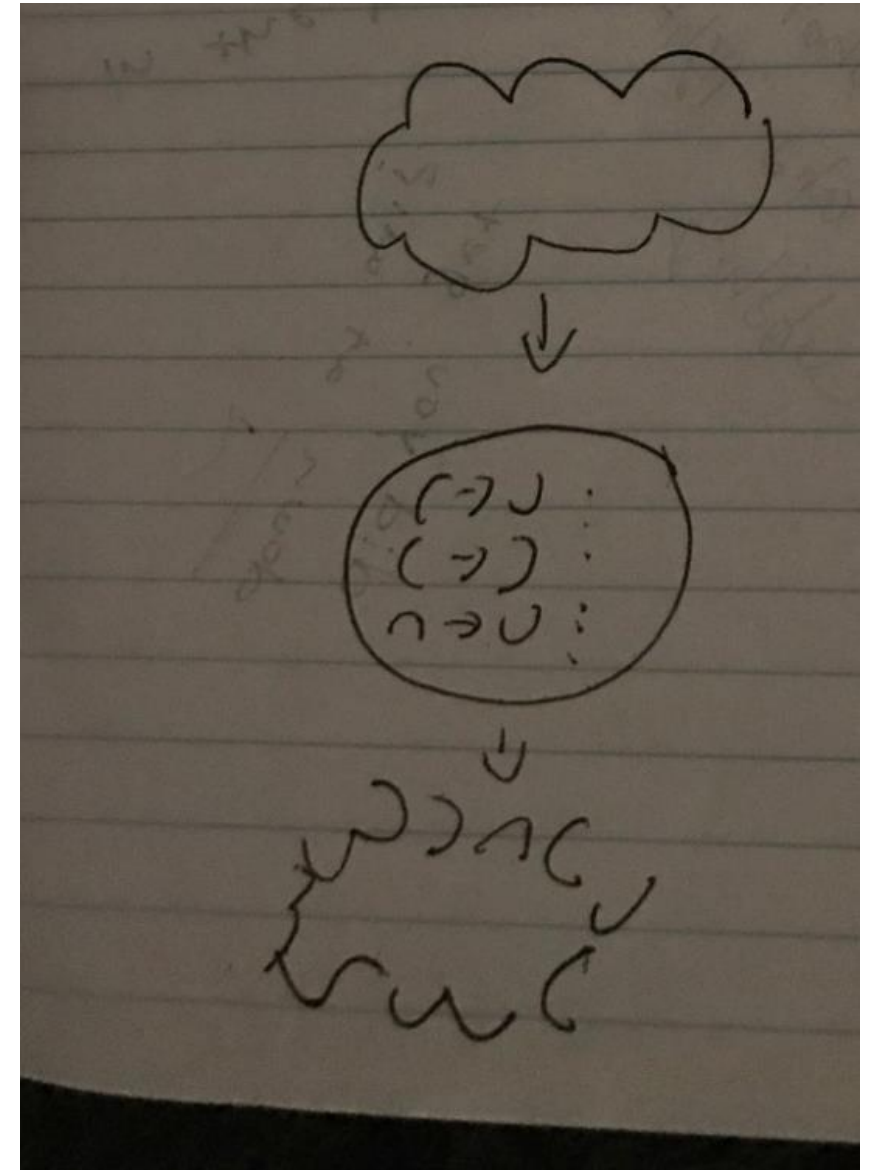
# Model 2: Black box

- Conceptually similar to access control: it's about who can get in
- Participants believe data does get altered, just not sure how



# Model 3: Cipher

- This model is a (further) refinement
- Encryption transforms data, AND
- That transformation involves substitutions
  - e.g., replacing one character with another
  - NOTE: modern encryption replaces large BLOCKS of characters, and the replacement is position & message-dependent

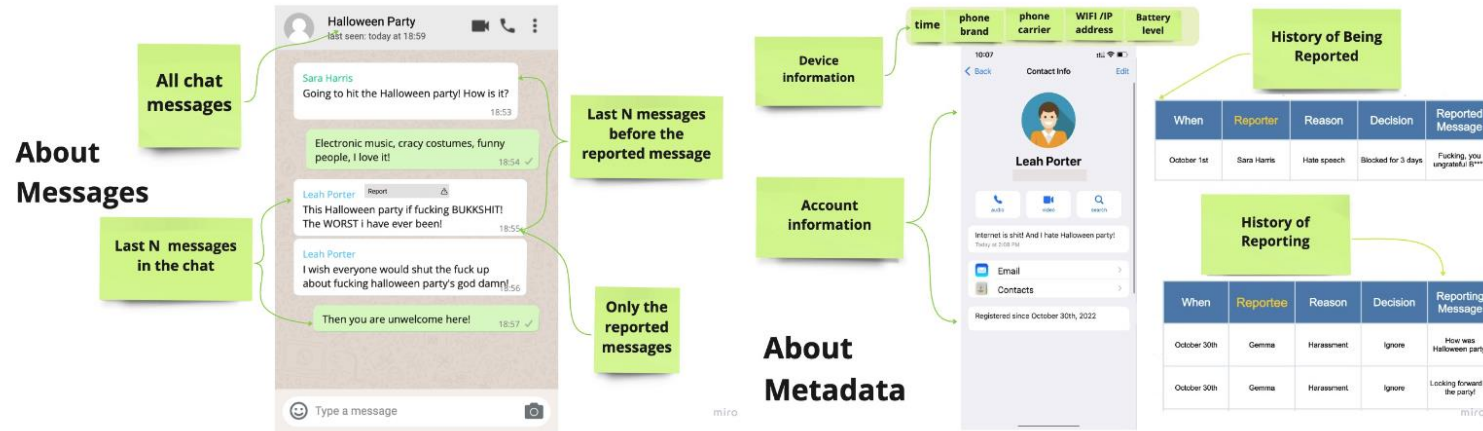


# Example 2: Mental models of abuse reporting on E2EE platforms

[“Is Reporting Worth the Sacrifice of Revealing What I’ve Sent”: Privacy Considerations When Reporting on End-to-End Encrypted Platforms \(SOUPS 2023\)](#)

- Interviews with 16 users of E2EE platforms (e.g., WhatsApp, Signal)
  - Card sorting
  - Hypothetical scenarios
- Focused on users’ understanding of data flows
  - What data is shared with E2EE platforms and moderators
  - How the data is stored and used by platforms
  - Related privacy concerns

# Card sorting activity



## When Reporting to Platform Moderators



# Results snapshot: stakeholders' access

- Platforms
  - Most E2EE messaging platforms have access to the reported message and contextual messages, except for Signal
  - When a message is reported platform can access account information and chat information (who you chatted with, frequency, when you chatted)
  - Device information (metadata)
- Platform moderators
  - Often seen as being the same entity as platforms and therefore having the same level of access
- Community moderators
  - Assumed to have the least access of the three, just account age or country
  - Reasoning: community moderators are part of the community already so platform gives them less

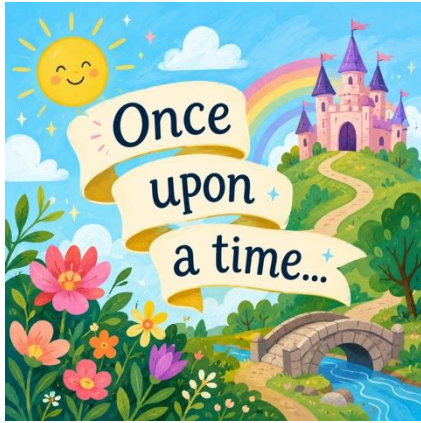
# Discussion

# Next time:

- Next reading response due Wednesday at 2 PM. Only one reading.
- Read through semester project instructions, ask questions on Wednesday
- Brainstorm ideas for your semester project. Be prepared to give a 2 minute pitch to some of your peers.

# Potential 2 minute pitch formula

Fairytale research pitch from Margo Seltzer (faculty at UBC)



## **"Once upon a time" ...**

- Context for understanding your idea
- What is the state of the world right now



## **Hero**

- Solution
- What do you propose doing to solve the problem



## **Villain**

- Problem



## **"Happily ever after" ...**

- Why should anyone care
- Impact if your solution works